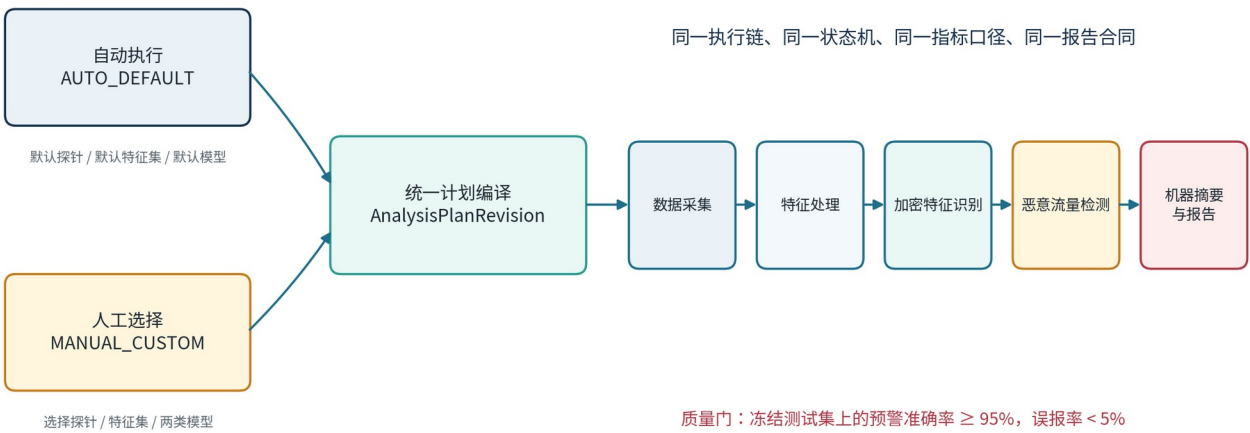


主业务闭环快速落地执行方案

自动执行与人工选择两种计划来源

数据采集 → 特征处理 → 加密特征识别 → 恶意流量检测 → 机器摘要与报告

目标质量门：冻结测试集上的预警准确率 ≥ 95%，误报率 < 5%



项目	traffic-analysis-platform
文档版本	v1.0
编制日期	2026-08-19
适用范围	主业务最小闭环、工程质量门与验收证据
文档性质	执行方案；不替代第三方检测质量报告

0. 文档控制与执行裁决

核心裁决

先完成一条可重复、可评估、可审计的恶意流量检测纵向闭环。自动执行和人工选择只改变计划来源，最终必须编译为同一个 AnalysisPlanRevision，进入同一个 AnalysisRun、同一套阶段、指标和报告合同。

项目	本版规定
主业务对象	一次 AnalysisRun：冻结计划、限定输入范围、五阶段执行、指标评价、机器摘要和证据清单。
自动执行	AUTO_DEFAULT：系统解析已批准的默认探针、特征集、加密识别模型和恶意检测模型。
人工选择	MANUAL_CUSTOM：授权用户从已批准目录选择探针、特征集和两类模型，不允许绕过计划编译器直连执行器。
工程闭环	输入、阶段回执、结果、状态和报告均可追踪；失败、零输入和不兼容均有明确结果。
质量闭环	在冻结测试集上重算预警准确率与误报率；达到 $\geq 95\%$ 和 $< 5\%$ 后才可声明质量门通过。
首版边界	优先 PCAP 可重复回放与已知攻击检测；实时高吞吐、未知攻击最终门、完整 MLOps 和全平台权限重构后续推进。

0.1 工程闭环与质量门分离

层次	完成判据	未通过时的状态
工程闭环	两种计划来源都能生成计划，完整执行五阶段，并形成可追踪的机器摘要和证据清单。	可以标记“链路已闭环”，但不得宣称质量达标。
质量门	冻结测试集、标签、切分、阈值和指标口径；预警准确率 $\geq 95\%$ ，误报率 $< 5\%$ 。	标记“质量门未通过”，进入数据、特征、模型或阈值整改。
项目验收	同一候选版本具备功能、质量、安全、性能、回滚与签认证据。	不得用局部测试替代项目级验收。

0.2 最小权限基线

全面权限重构不作为主业务闭环的前置，但以下最小授权必须同步冻结：

- 系统服务主体可触发 AUTO_DEFAULT，但只能使用已批准默认计划。
- 安全分析人员可创建 MANUAL_CUSTOM 计划，只能选择本人租户内、状态为已批准的探针、特征集和模型。
- 计划审批与计划编辑分离；生产执行前由服务端重新校验权限、租户和计划版本。

- Run 查看、取消、重试、报告下载和证据导出分别授权，所有拒绝与高风险动作写审计。

目录

章节	内容
1	目标、范围与成功标准
2	总体方法与工作包
3	W0：合同、指标与数据基线冻结
4	W1-W2：数据集与两种计划来源
5	W3：数据采集闭环
6	W4：特征处理闭环
7	W5：加密特征识别闭环
8	W6：恶意流量检测闭环
9	W7：95%/5% 质量门
10	W8：机器摘要与报告
11	W9：端到端联调与验收
12	并行执行编组与里程碑
13	风险、暂停项与回滚
14	立即执行清单
附录 A	核心数据合同
附录 B	机器报告模板

阅读方式

项目负责人先读第 1、2、11、14 章；采集与数据团队读第 3-6 章；算法团队读第 6-9 章；后端、前端和测试团队读第 2、10-14 章。

1. 目标、范围与成功标准

1.1 唯一主业务链

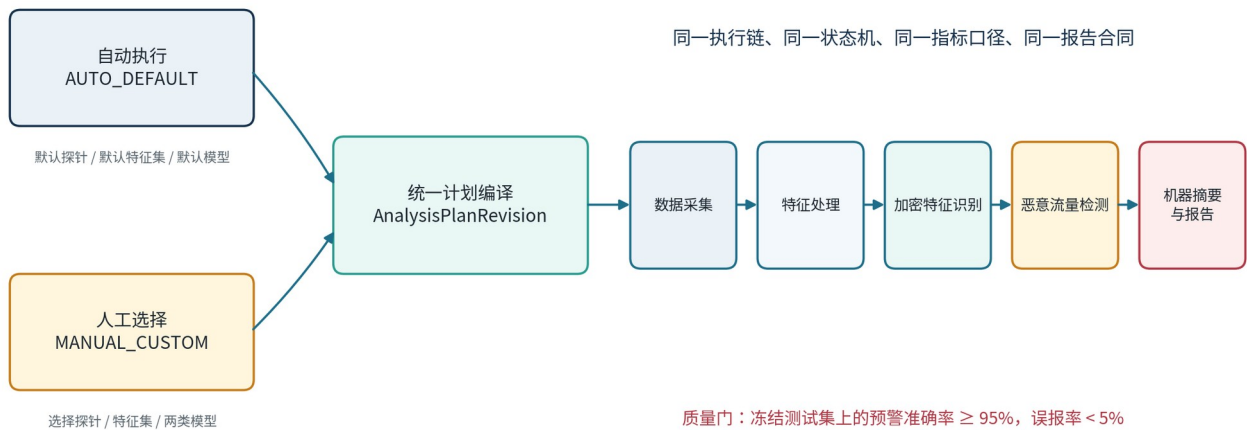


图 1 两种计划来源汇聚为同一执行链

最终目标

针对一个冻结的分析范围，由 AUTO_DEFAULT 或 MANUAL_CUSTOM 生成不可变计划，完成数据采集、特征处理、加密识别、恶意检测和机器摘要；报告可重算 TP、FP、FN、TN，并给出质量门是否通过。

1.2 首版纳入与暂缓范围

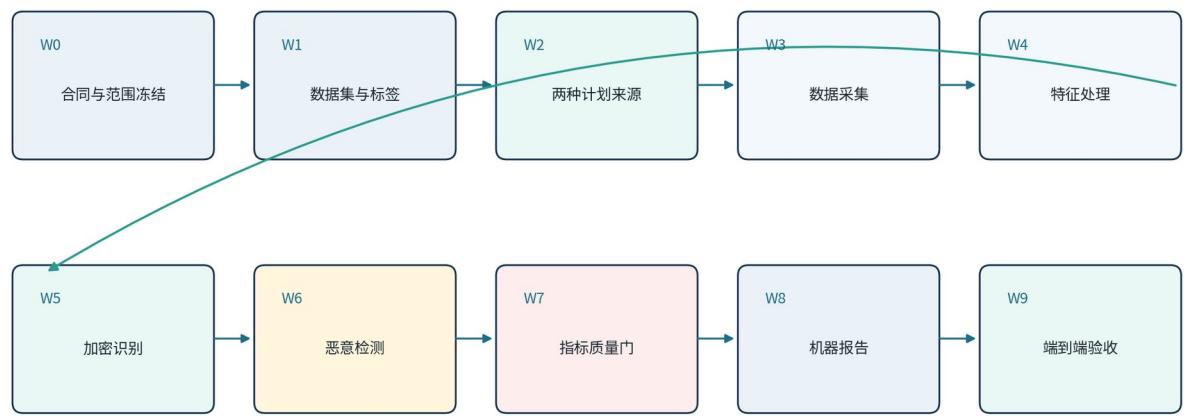
纳入首版闭环	暂缓到后续阶段
PCAP 可重复回放；已知攻击二分类/多分类；默认与人工计划；五阶段回执；机器报告；指标脚本；同候选证据。	100Gbps/512Mpps 性能验收；任意自由 DAG；完整四源融合；GNN 攻击链；复杂 SOAR；完整人读大模型报告。
固定且可审计的特征集、加密识别模型和恶意检测模型目录。	允许用户上传任意模型或脚本直接执行。
冻结测试集上的预警准确率与误报率门。	把训练集或小样本结果当作最终验收。
未知、未执行、不兼容、错误和零输入的显式结果。	用“没有告警”代替明确阴性。

1.3 成功标准

- 两种计划来源均编译为同一 AnalysisPlanRevision，并绑定版本、哈希和允许的资源 exact-set。
- 同一输入通过五个阶段，每阶段均有输入、输出、拒绝、失败数量与不可变回执。
- 每个输入必须得到 POSITIVE、NEGATIVE、INCONCLUSIVE、INCOMPATIBLE、ERROR 或 NOT_RUN 之一。
- 机器摘要能够关联计划、数据、特征、模型、阈值、结果、指标和证据清单。
- 冻结测试集上预警准确率达到或超过 95%，误报率严格低于 5%；召回率、F1 和延迟同步报告。
- 同一 Git 候选、镜像、配置、数据集和环境下可以重复运行并得到可解释的一致结果。

2. 总体方法与工作包

先形成确定性工程闭环，再通过冻结评测集关闭质量门



每个工作包均输出：合同 / 代码或配置 / 测试 / 指标 / 不可变证据

图 2 主业务闭环工作包路线

工作包	目标	核心产出	退出门
W0	合同与范围冻结	主链对象、指标、错误语义、权限最小基线	合同评审通过
W1	数据集与标签基线	PCAP、标签、切分、数据清单和哈希	数据可重现
W2	两种计划来源	默认解析器、人工选择器、统一计划编译	两种来源同合同
W3	数据采集	PCAP/探针到 Flow/Session 的守恒链	流量计数闭合
W4	特征处理	exact-set 特征计算、缺失与质量检查	特征质量通过
W5	加密识别	加密类型/协议/指纹/表示结果	识别结果可消费
W6	恶意检测	规则/模型推理和每输入显式结果	检测输出守恒
W7	指标质量门	混淆矩阵、预警准确率、FPR、Recall、F1	≥95% / <5%
W8	机器报告	摘要、指标、关键发现、限制和证据 manifest	报告可追踪
W9	端到端验收	正负零错场景、重试、回滚和同候选证据	闭环发布裁决

2.1 固定实施原则

- 先合同、后迁移、再消费者、最后生产者和 UI；避免先写页面再猜接口。
- 先确定性 PCAP 回放，后实时流量；先已知攻击质量门，后未知攻击开放集质量门。
- AUTO_DEFAULT 与 MANUAL_CUSTOM 不建立两套 Topic、状态机或报告，只建立两种计划编译入口。
- 阈值只能在验证集上调整，测试集一次冻结后不得反复用于调参。
- 功能 PASS、质量 PASS、生产 PASS 和第三方 PASS 分开登记。

3. W0：合同、指标与数据基线冻结

3.1 必须先冻结的对象

对象	首版字段	关键约束
AnalysisPlanRevision	plan_source、probe_ids、feature_set_id、encryption_model_id、malware_model_id、thresholds、revision、hash	不可变；两种来源都由同一编译器产生。
AnalysisRun	tenant、task、plan、window、dataset/capture、candidate、profile、environment、state	一次有界执行；终态不可回退。
StageReceipt	run、phase、node、attempt、input/output/error/count、fence、hash	append-only；重复回执幂等，旧 fence 拒绝。
DetectionResult	object_id、truth、prediction、score、disposition、detector_version	每输入必须有一个显式结果。
MachineSummary	范围、版本、计数、指标、结论、限制、evidence_manifest_hash	与 Run 终态同一候选冻结。

3.2 指标口径冻结

指标	公式	本项目口径
预警准确率（Alert Precision）	$TP / (TP + FP)$	目标 $\geq 95\%$ ；只统计进入预警列表的样本。
误报率（False Positive Rate）	$FP / (FP + TN)$	目标 $< 5\%$ ；分母是实际正常样本。
召回率（Recall）	$TP / (TP + FN)$	必须同步报告，防止通过减少告警虚增精度。
F1	$2 \times Precision \times Recall / (Precision + Recall)$	用于平衡精度与召回。
检测延迟	alert_time - source_event_time	按 P50/P95 报告；首版 PCAP 回放独立记录回放倍率。

口径警告

“总体 Accuracy” 不能代替“预警准确率”。当正常样本远多于恶意样本时，即使模型几乎不告警，总体 Accuracy 也可能很高。质量门必须同时查看 Precision、FPR、Recall 和混淆矩阵。

3.3 W0 执行清单

- [] 确定首版任务：PCAP_REPLAY + KNOWN_ATTACK_CORE + MACHINE_SUMMARY_ONLY。
- [] 冻结 Plan、Run、Receipt、Result、Summary 五类 schema 与枚举。
- [] 冻结测试集和验证集，建立 dataset_manifest.json 与文件 SHA-256。
- [] 冻结预警准确率、误报率、召回率和报告口径。
- [] 定义最小权限 scope、租户约束、审计字段和错误码。
- [] 形成 W0 合同评审记录，未通过前不得并行堆叠 UI 和模型功能。

4. W1-W2：数据集与两种计划来源

4.1 W1 数据集与标签基线

步骤	工作内容	产出	退出标准
1	选择一套可公开复现的数据集和一套自建/园区样本，统一转换为 PCAP + 标签清单。	dataset_catalog.yaml	文件、标签、来源和许可可追踪。
2	按攻击家族、时间或采集源切分 train/validation/test，禁止同一会话跨集合。	split_manifest.json	无数据泄漏；测试集冻结。
3	生成每个 PCAP 的 sha256、包数、流数、标签分布和时间范围。	dataset_manifest.json	同一清单可重放并核对数量。
4	准备四类基础 fixture：恶意、正常、零输入、损坏/不兼容。	fixtures/	正负和异常路径均可测试。

4.2 W2 自动执行计划

用户输入	系统解析	冻结结果
任务定义、时间窗/PCAP、分析范围	默认探针集合、默认特征集、默认加密识别模型、默认恶意检测模型、默认阈值	AUTO_DEFAULT AnalysisPlanRevision + execution_spec_sha256

- 默认目录必须是已批准版本；目录变化不会影响已经物化的 Run。
- 默认解析失败必须返回 PLAN_NOT_READY，不得静默选择任意模型。
- 自动执行主体使用服务身份，但仍需记录 tenant、definition、plan 和触发原因。

4.3 W2 人工选择计划

选择项	首版允许范围	校验规则
探针	选择当前租户内、在线或可回放、状态已批准的探针。	越权、离线、能力不匹配直接阻断。
特征集	从已注册 exact-set 中选择；记录版本、schema 和必需输入。	不能输入自由脚本；模型所需特征必须覆盖。
加密识别模型	选择已批准且与特征 schema 兼容的版本。	输出合同必须可被恶意检测阶段消费。
恶意检测模型	选择已批准的规则/模型 exact-set 与阈值。	实验模型与生产模型分级；生产执行可要求审批。

统一原则

人工选择完成后，前端只提交选择意图；服务端重新解析目录、校验兼容性并生成不可变 MANUAL_CUSTOM AnalysisPlanRevision。页面不得直接调用探针、Flink 或模型接口。

5. W3：数据采集闭环

5.1 目标

把冻结 PCAP 或有界实时窗口稳定转换为 Flow/Session 输入，并证明输入、输出、拒绝和丢失数量。

步骤	执行动作	关键产出	质量检查
W3-1	解析 source manifest，校验对象 hash、大小、标签清单和时间范围。	SourceReady receipt	对象与计划完全一致。
W3-2	向指定探针下发 typed capture/replay command；命令携带 run_id、window、lease 和 fencing token。	Dispatch receipt	旧 token、错误租户或重复命令被拒绝/幂等。
W3-3	Probe 执行 PCAP 回放或有界采集，复用统一数据出口进入 ingest gateway/Kafka。	Flow events	禁止调度中心自行解析 PCAP。
W3-4	会话化前输出 source fence：包数、流数、拒绝数、时间水位和最后序号。	SOURCE_FENCE receipt	input = accepted + rejected + failed。
W3-5	对恶意、正常、零输入和损坏对象运行固定测试。	W3 evidence bundle	每种场景有明确终态。

5.2 W3 输出合同

字段组	必需字段
身份	tenant_id、task_id、run_id、plan_revision_sha256、window_id、probe_id
流标识	flow_id/community_id、src/dst、协议、开始/结束时间
计数	packet_count、byte_count、accepted_count、rejected_count、error_count
追踪	event_id、trace_id、lease_epoch、fencing_token、source_object_sha256
标签（评测专用）	ground_truth、family、split；生产链不得依赖标签推理

W3 退出门

同一 PCAP 重放多次，source manifest 与 Flow/Session 计数可解释；零输入返回 NO_DATA；损坏或 hash 不一致返回明确失败；旧 fence 回执不能推进当前 Run。

6. W4：特征处理闭环

6.1 特征 exact-set

层级	首版建议特征	用途
基础流特征	duration、packet/byte count、packet/byte rate、方向比、长度/间隔统计	提供稳定的通用检测基线。
TLS/加密特征	TLS version、cipher suite、JA3/JA4、SNI、证书元数据、握手序列	支持加密类型与应用指纹识别。
行为特征	周期性、连接频率、目的地多样性、失败率、beacon score	支持 C2 与异常行为检测。
可选序列表示	首 N 包方向、长度和时间间隔序列	供深度模型使用；必须冻结长度和填充策略。

6.2 执行步骤

1. 根据 AnalysisPlanRevision 编译 selected calculator exact-set；未选择的计算器必须零调用。
2. 对每个 Flow/Session 产生 FeatureVector，并携带 feature_set_id、schema_version 和 feature_hash。
3. 显式记录缺失、无法计算、超范围和异常值，不允许默认填零后伪装有效。
4. 生成特征质量报告：覆盖率、缺失率、无穷值、离群值、分布和标签关联检查。
5. 对训练、验证、测试集使用同一变换；标准化参数只能由训练集拟合。

6. 提交 FEATURE_EXTRACTION receipt，关闭输入、输出、失败和跳过数量。

6.3 W4 退出门

检查项	通过标准
数量守恒	特征成功 + 不兼容 + 错误 + 未执行 = 阶段输入。
版本可追踪	每行带 feature_set_id、schema_version、plan/run 和 hash。
无泄漏	测试标签未进入特征；标准化、编码和阈值不读取测试集统计。
兼容性	加密识别模型和恶意检测模型所需字段均由计划 exact-set 提供。
复现性	同一输入、同一计划和同一候选输出 hash 稳定或差异可解释。

7. W5：加密特征识别闭环

7.1 阶段职责

语义边界

本阶段回答“该流量是什么类型的加密流量、具有什么指纹或表示”，不直接给出恶意结论。恶意检测阶段消费原始特征与 RecognitionOutcome 的复合输入。

输入	处理	输出 RecognitionOutcome
FeatureVector、TLS/序列特征、plan/model version	规则或模型识别；兼容性检查；置信度校准	encrypted、protocol/application、fingerprint/family、embedding/reference、confidence、disposition

7.2 执行步骤

1. 加载计划指定的加密识别模型 exact version，并校验模型签名、schema 和所需特征。
 2. 对每个输入产生显式 RecognitionDisposition：识别成功、不兼容、证据不足、错误或未执行。
 3. 输出应用/协议类别、指纹、置信度和可选 embedding；保留模型版本与推理参数。
 4. 校验输出能被 W6 的恶意检测模型消费，不允许只有 ClickHouse 旁路结果而主链没有 typed outcome。
 5. 提交 ENCRYPTED_RECOGNIZER receipt，并对识别结果数量和 hash 做对账。

7.3 阶段指标

指标	用途	是否作为 95%/5% 最终门
加密/非加密识别准确率	验证前置分类是否可靠。	否，单独报告。

指标	用途	是否作为 95%/5% 最终门
应用/协议分类 Macro-F1	避免大类掩盖小类。	否，单独报告。
置信度校准 ECE/Brier	判断置信度能否用于下游。	否，推荐。
不兼容率/未执行率	暴露计划与数据不匹配。	是，影响完整性，不得隐藏。

8. W6：恶意流量检测闭环

8.1 输入与输出

输入	检测分支	统一输出
FeatureVector + RecognitionOutcome + plan threshold	规则检测、行为模型、恶意流量模型；首版可选择一个主模型和一个规则分支	每输入×检测器 DetectorDisposition + score + predicted label + evidence references

8.2 必须显式覆盖的六类结果

Disposition	含义	是否可直接视为正常
POSITIVE	检测器给出可信恶意判定。	否，进入预警与证据聚合。
NEGATIVE	检测器完成执行并明确判定为阴性。	仅在完整性通过时可用于总体无威胁结论。
INCONCLUSIVE	证据不足，无法确定。	否。
INCOMPATIBLE	输入与模型/规则不兼容。	否。
ERROR	检测执行失败。	否。
NOT_RUN	计划要求但未执行。	否。

8.3 执行步骤

1. 先建立 RandomForest/XGBoost 或稳定现有模型作为基线，再接入目标模型；所有模型共享同一评测脚本。
2. 只执行计划冻结的 detector exact-set，禁止遍历租户全部模型。
3. 阈值在验证集上选择并随计划冻结；测试运行不得动态重新选阈值。
4. 生成每输入结果、告警候选、证据引用和模型解释摘要。
5. 对规则分支与模型分支做聚合，保持每个输入的六类结果守恒。
6. 提交 RULE_DETECTION、BEHAVIOR_DETECTION 和 DETECTION_AGGREGATE receipts。

首版与开放集边界

95%/5% 质量门先针对冻结的已知攻击评测集。未知攻击识别应另立 Unknown Recall、AUROC、OSCR、FPR95 等指标，不能把已知攻击的 95%/5% 直接解释为开放集能力。

9. W7：95%/5% 指标质量门



图 3 混淆矩阵与核心质量门

9.1 评测执行顺序

1. 冻结数据版本、split manifest、标签字典、计划 revision、特征集、模型版本和阈值。
2. 对验证集运行阈值搜索；记录候选阈值、Precision-Recall 曲线和选择理由。
3. 一次性对冻结测试集推理，保存逐样本预测，不在测试结果上再次调参。
4. 按统一脚本计算 TP、FP、FN、TN、Precision、FPR、Recall、F1、ROC-AUC/PR-AUC。
5. 按攻击家族、加密/非加密、数据源和计划来源分层报告，避免总体指标掩盖弱项。
6. 自动计划和人工计划若使用相同 exact-set，输出应等价；不同配置则分别登记质量门。
7. 生成 metric_manifest.json，绑定数据、代码、模型、阈值和结果文件 hash。

9.2 质量门判定

门	PASS 条件	FAIL 后动作
G7-PRECISION	Alert Precision ≥ 0.95	检查标签、阈值、误报样本、特征和模型；不得只减少告警数量。
G7-FPR	FPR < 0.05	分析正常样本误报分布，增加负样本、校准阈值或特征。
G7-RECALL	同步报告并满足项目签字下限	防止高 Precision 低 Recall；若下降则重新平衡阈值和损失。
G7-INTEGRITY	逐样本预测数等于测试输入数，ERROR/NOT_RUN 可解释	链路或兼容性问题先修复，不能直接计算通过。

门	PASS 条件	FAIL 后动作
G7-REPRODUCE	同候选重复运行指标差异在批准容差内	检查随机种子、并行非确定性、数据顺序和模型版本。

禁止性规则

不得把训练集结果、验证集最佳点、少量演示样本或告警列表中的“命中率”直接写成最终 95%/5% 结论。质量门只接受冻结测试集上的逐样本预测和可复算混淆矩阵。

10. W8：机器摘要与报告

10.1 报告生成原则

- 机器摘要是 Run 终局的一部分；HTML/PDF 人读报告是从冻结摘要异步派生的可选制品。
- 报告失败不反向修改 RunState；报告状态独立为 QUEUED、GENERATING、VERIFYING、AVAILABLE、FAILED。
- 报告只使用同一 run、plan、candidate、profile、environment 的冻结数据和证据。
- 若质量门失败，报告必须明确写“工程链路完成，质量门未通过”，不得弱化。

10.2 机器摘要最小结构

章节	内容
执行摘要	任务、计划来源、时间范围、数据源、Run 终态和总体结论。
计划与版本	探针、特征集、加密识别模型、恶意检测模型、规则、阈值和 hash。
数据统计	PCAP/包/流/会话/特征输入输出、拒绝、错误和零输入。
加密识别结果	协议、应用、指纹、识别分布、不兼容和错误。
恶意检测结果	六类 disposition、告警列表、攻击类型、置信度和关键证据。
指标评价	TP/FP/FN/TN、Precision、FPR、Recall、F1、分层指标和质量门裁决。
限制与异常	未覆盖范围、数据偏差、模型限制、ERROR/NOT_RUN 和不可比较项。
证据清单	数据 manifest、结果文件、receipt、模型/代码/配置 hash 和下载审计。

10.3 报告退出门

[] 报告中的每个数字可从逐样本结果与阶段计数重新计算。

- [] 报告显示 PlanSource，但不把 AUTO_DEFAULT/MANUAL_CUSTOM 误写成两套执行系统。
- [] NO_DATA、INCONCLUSIVE、INCOMPATIBLE、ERROR 和 NOT_RUN 不显示为“安全”。
- [] 只有 IntegrityState=VERIFIED 且报告对象 hash 校验通过后才允许下载。

11. W9：端到端联调与验收

11.1 首批端到端场景矩阵

编号	场景	预期结果
E2E-01	AUTO_DEFAULT + 恶意 PCAP	完整执行；产生 POSITIVE、告警和报告。
E2E-02	AUTO_DEFAULT + 正常 PCAP	完整执行；明确 NEGATIVE，非“无输出”。
E2E-03	AUTO_DEFAULT + 零输入窗口	Run 形成 NO_DATA；不显示未发现威胁。
E2E-04	AUTO_DEFAULT + 损坏/Hash 不符	在采集前失败；不进入后续阶段。
E2E-05	MANUAL_CUSTOM + 合法组合	生成独立 PlanRevision，进入同一执行链。
E2E-06	MANUAL_CUSTOM + 不兼容特征/模型	Preflight 阻断并说明缺失字段。
E2E-07	MANUAL_CUSTOM + 越权探针/模型	403 + 拒绝审计；不物化 Run。
E2E-08	同幂等键同载荷重放	返回原 Trigger/Task/Run。
E2E-09	同幂等键异载荷	409 冲突；原事实不变。
E2E-10	阶段失败后重试	创建新 StageAttempt，不覆盖历史 attempt。
E2E-11	整任务重试	同一 Task 下创建新 Run，旧 Run 只读。
E2E-12	报告生成失败	Run 保持原终态，ReportState=FAILED，可独立重试。

11.2 Run 完成定义（Definition of Done）

- [] Trigger、Task、Run、Plan、Window、Candidate、Profile、Environment 身份一致。
- [] 五阶段 required nodes 均有可采用的终态 attempt 和匹配 receipt。
- [] 输入、输出、拒绝、错误、不兼容和未执行数量守恒。
- [] 每个测试输入有逐样本预测与 ground truth，可复算混淆矩阵。
- [] RunClosureManifest、MachineSummary 和 EvidenceManifest 同候选冻结。
- [] 自动与人工计划均通过对应 E2E 场景；权限拒绝与高风险动作有审计。
- [] 回滚后旧路径仍可用；新分支可由 feature flag 关闭。
- [] 质量门状态明确：PASS 或 FAIL，不允许 UNKNOWN 被显示为成功。

最终发布裁决

只有 W0-W9 全部满足同候选证据，且 G7-PRECISION 与 G7-FPR 同时通过，才可声明“主业务闭环完成并达到 95%/5% 质量门”。否则必须使用更精确的状态：工程闭环完成 / 质量门未通过 / 项目级验收待完成。

12. 并行执行编组与里程碑

12.1 建议并行 workflow

workflow	主要责任	并行任务	依赖交付
A 合同与控制面	架构/Go 后端	W0 合同、计划编译、Run/Receipt、幂等、审计、机器摘要	所有团队共用 schema 与错误码。
B 数据与采集	Rust/数据工程	数据集 manifest、PCAP 回放、Flow/Session、source fence	向特征链提供可重复输入。
C 特征与加密识别	Flink/算法	特征 exact-set、质量报告、RecognitionOutcome	向恶意检测提供复合输入。
D 恶意检测与评测	算法/测试	基线模型、目标模型、阈值、逐样本预测、指标脚本	输出冻结质量证据。
E 报告与产品	前端/后端/测试	运行监控最小页、机器摘要、报告下载、错误态	消费权威 API，不直接编排执行器。
F QA 与证据	测试/SRE/安全	E2E 矩阵、回滚、审计、同候选证据索引	负责最终门禁裁决。

12.2 四个里程碑

里程碑	必须完成	退出门
M1：确定性数据链	W0-W4；固定 PCAP 能稳定形成 Flow/Session/Feature。	数量、版本和 hash 可对账。
M2：检测链	W5-W6；加密识别与恶意检测产生逐样本显式结果。	六类 disposition 守恒。
M3：质量门	W7；冻结测试集上重算指标。	Precision $\geq$ 95%，FPR < 5%，Recall/F1 可接受。
M4：产品闭环	W8-W9；两种计划来源、报告、权限、重试、回滚和证据。	端到端 DoD 全部通过。

12.3 交付目录建议

目录	内容
contracts/analysis/	plan、run、receipt、result、summary schema 与错误码。
data/manifests/	dataset、split、fixture、label 与 hash 清单。
tests/analysis/	单元、合同、集成、E2E、质量门和重复性测试。
evidence/analysis/<candidate>/	逐阶段 receipts、预测、指标、报告、环境与镜像清单。
doc/07_alignment/	主业务合同、执行台账、差异与最终裁决。

13. 风险、暂停项与回滚

13.1 高优先级风险

风险	问题	影响	控制措施
R1	数据泄漏导致虚高指标	会话/攻击家族跨训练与测试集。	按时间/家族/源切分；冻结 split manifest。
R2	只追求 Precision 导致 Recall 崩溃	减少告警可轻易抬高精度。	强制同时报告 Recall、F1 和混淆矩阵。
R3	人工计划绕过服务端校验	直接调用探针/模型造成越权和不可复现。	前端仅提交意图；服务端编译、授权和冻结。
R4	无输出被当作 NEGATIVE	链路失败被误报成安全。	六类 disposition + 完整性门。
R5	计划或模型版本漂移	同一 Run 不可复现。	不可变 revision、双 hash 和同候选证据。
R6	阶段双写或重复消费	数量与指标失真。	outbox/inbox、幂等键、receipt fence 和对账。
R7	先做复杂 UI 延误主链	页面完成但检测无可验证闭环。	UI 只实现最小运行、详情和报告。
R8	用已知攻击门冒充未知攻击能力	开放集结论不可信。	未知攻击另立独立指标和数据切分。

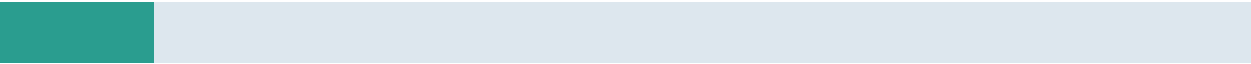
13.2 当前暂停项

- 全平台角色体系与 IAM 全面重构：只先完成分析域最小权限目录和统一中间件接入。
- 任意 DAG 编排器：首版固定五阶段和技术闸门。
- 实时高吞吐性能验收：先以可重复 PCAP 关闭业务与质量门，再做性能 Profile。
- 未知攻击最终质量门：待已知攻击闭环稳定后独立推进。
- 复杂人读报告与大模型解释：机器摘要先成为真源，后续异步派生。
- 完整 MLOps 自动训练：首版固定模型和阈值，先证明评测可复现。

13.3 回滚策略

对象	回滚方式	禁止操作
计划与 API	feature flag 关闭新入口；历史 revision 保留只读。	删除已物化 Plan/Run。
Kafka/Flink	新 topic/operator 默认关闭或 shadow；保留旧 consumer 和 savepoint。	静默复用不兼容 UID/state。
数据库	只做 additive migration；切读前对账。	直接覆盖旧列含义或删除表。
模型与阈值	恢复到上一个批准版本；保留预测和指标证据。	重写历史 Run 所用版本。
报告	报告可重试或重新派生；机器摘要不可变。	报告失败回退 Run 终态。

14. 立即执行清单



最短路径

第一个必须跑通的闭环是：AUTO_DEFAULT + ON_DEMAND + PCAP_REPLAY + 固定特征集 + 固定加密识别模型 + 固定恶意检测模型 + 冻结测试集 + 机器摘要。随后使用相同组件完成 MANUAL_CUSTOM 等价运行。

- [] 指定主业务闭环负责人和 W0-W9 各工作包 owner。
- [] 冻结首版数据集、测试集、标签字典、PCAP fixture 和 SHA-256 清单。
- [] 签字确认预警准确率、误报率、Recall、F1 和零输入口径。
- [] 冻结 AnalysisPlanRevision、AnalysisRun、StageReceipt、DetectionResult、MachineSummary schema。
- [] 注册一套默认探针、特征集、加密识别模型、恶意检测模型和阈值。
- [] 实现 AUTO_DEFAULT resolver，并验证不可变计划 hash。
- [] 实现 MANUAL_CUSTOM 选择、兼容性 preflight 和服务端权限校验。
- [] 用恶意、正常、零输入、损坏 PCAP 跑通 W3 数据采集。
- [] 完成 selected feature exact-set 与特征质量报告。
- [] 输出 typed RecognitionOutcome，并接入恶意检测复合输入。
- [] 产生逐样本六类 DetectorDisposition 与预测文件。
- [] 运行统一指标脚本并生成 metric_manifest.json。
- [] 针对 FP、FN 和不兼容样本开展误差分析，整改数据、特征、模型或阈值。
- [] 达到 Precision ≥95%、FPR <5% 后冻结模型、阈值和测试证据。
- [] 生成 MachineSummary、EvidenceManifest 和 PDF 报告。
- [] 运行 E2E-01 至 E2E-12，验证幂等、越权、重试、报告失败和回滚。

[] 生成同一候选的最终证据索引和发布裁决。

14.1 每日/每次合并必须回答的问题

问题	必须能回答
现在处理的是什么？	明确 Task、Plan、Run、数据版本和工作包。
输入输出是否闭合？	每阶段数量守恒，错误和跳过有原因。
结果能否复现？	同一候选、配置、数据和随机种子可重复。
指标是否可信？	测试集冻结，阈值未在测试集调优，混淆矩阵可复算。
失败是否安全？	未知、零输入、未运行和完整性失败不显示为成功。
是否可回滚？	新链路可关闭，旧链路和历史事实不被删除。

附录 A：核心数据合同示例

A.1 AnalysisPlanRevision

```
{
  "plan_source": "AUTO_DEFAULT | MANUAL_CUSTOM",
  "probe_ids": ["probe-01"],
  "feature_set": {"id": "tls-behavior-v1", "revision": 3, "sha256": "..."},
  "encryption_model": {"id": "enc-rec-v2", "revision": 5, "sha256": "..."},
  "malware_model": {"id": "mal-det-v4", "revision": 8, "sha256": "..."},
  "thresholds": {"alert": 0.87},
  "dataset_or_window": {"source": "pcap", "manifest_sha256": "..."},
  "execution_spec_sha256": "..."
}
```

A.2 DetectionResult

字段组	示例字段
身份	tenant_id、task_id、run_id、plan_hash、object_id、detector_id/version
真值与预测	ground_truth（评测）、predicted_label、score、threshold
显式结果	POSITIVE / NEGATIVE / INCONCLUSIVE / INCOMPATIBLE / ERROR / NOT_RUN
证据	feature_hash、recognition_outcome_id、rule/model evidence refs
追踪	event_id、receipt_id、candidate/profile/environment、row_sha256

A.3 RunOutcome 六轴

轴	示例值	含义
RunState	SUCCEEDED / PARTIALLY_SUCCEEDED / FAILED / CANCELLED	执行状态
FindingConclusion	THREAT_FOUND / NO_THREAT_OBSERVED / INCONCLUSIVE / NO_DATA / NOT_EVALUATED	总体机器结论
Completeness	COMPLETE / PARTIAL / INCOMPLETE / UNKNOWN	范围覆盖情况
IntegrityState	VERIFIED / UNVERIFIED / FAILED	证据与回执可信度
RiskSeverity	CRITICAL / HIGH / MEDIUM / LOW / NONE / UNKNOWN	已发现风险的严重度
ReportState	NOT_REQUESTED / QUEUED / GENERATING / VERIFYING / AVAILABLE / FAILED	人读报告状态

附录 B：机器报告模板

报告章节	必须包含
1. 执行摘要	任务名称、Run ID、计划来源、执行状态、机器结论、质量门裁决。
2. 分析范围	数据源/PCAP、时间窗、探针、标签版本、输入规模。
3. 计划与版本	特征集、加密识别模型、恶意检测模型、规则、阈值和 hash。
4. 阶段统计	五阶段输入、输出、拒绝、错误、不兼容、未执行及耗时。
5. 加密识别	协议/应用/指纹分布、置信度、不兼容和错误。
6. 恶意检测	告警、攻击类别、六类结果、Top 证据和解释。
7. 指标评价	TP/FP/FN/TN、Precision、FPR、Recall、F1、分层指标。
8. 质量门裁决	95%/5% 是否通过；失败项、原因和整改建议。
9. 限制说明	数据偏差、未覆盖攻击、计划限制、失败和不可比较项。
10. 证据清单	数据、配置、模型、代码、预测、receipts、summary 和 report hash。

B.1 最终签署页应记录

- [] Git commit / candidate ID / 镜像 digest / 数据库迁移版本。
- [] 数据集 manifest、split manifest、模型、阈值和预测结果 SHA-256。
- [] 运行环境、开始结束时间、执行人/服务主体与审批人。
- [] 工程闭环、质量门、生产门和第三方门的独立状态。
- [] 已知限制、回滚入口和后续开放集评测计划。

文档结束

本方案的唯一优先级是：先让一条可信检测链在两种计划来源下可重复闭环，并用冻结数据证明 95%/5% 质量门；其余平台能力围绕该闭环逐步扩展。